

Лабораторная работа №3

Кибербезопасность предприятия

Боровиков Даниил Хрусталев Влад Гисматуллин Артём Чесноков Артёмий Кон-
нова Татьяна Нефедова Наталья Уткина Алина Бансимба Клодели

Российский университет дружбы народов, Москва, Россия

В рамках лабораторной работы проведен анализ трех уязвимых узлов с различными типами уязвимостей. Использовались инструменты мониторинга и защиты: ViPNet IDS NS, Security Onion, а также встроенные средства операционных систем для обнаружения и нейтрализации атак.

- **ViPNet IDS NS** - обнаружение сетевых атак
- **Security Onion** - мониторинг сетевой безопасности
- **Системные утилиты** (ss, netstat, taskkill) - анализ процессов и соединений

Процесс выполнения лабораторной работы

Уязвимый узел: WpDiscuz

Уязвимый узел: WpDiscuz

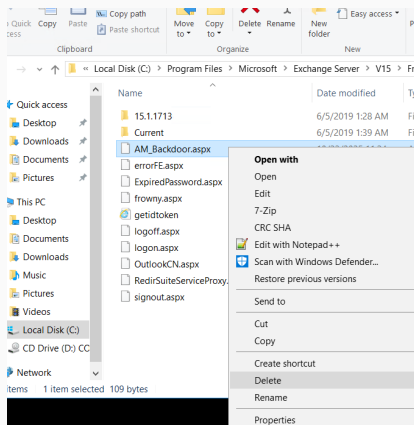


Рис. 1: Вредоносные файлы

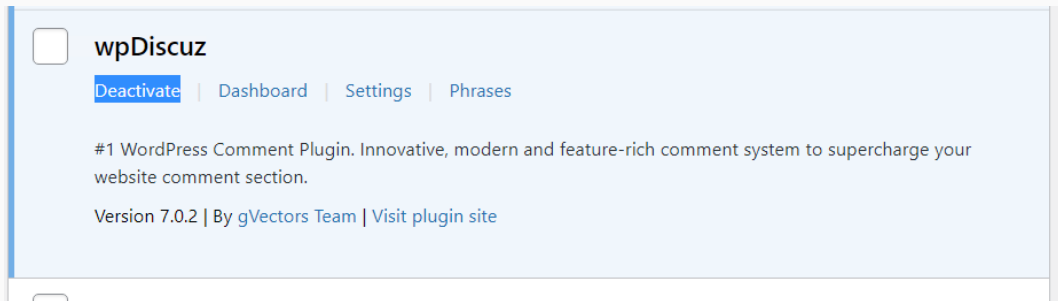


Рис. 2: Активная версия плагина

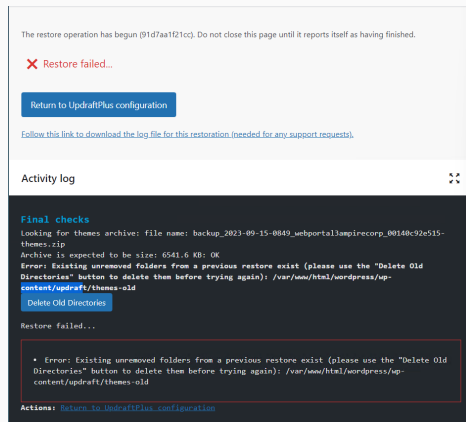


Рис. 3: Восстановление из резервной копии

UpdraftPlus Restoration — Restore files from: Sep 15, 2023 8:49

Restoring will replace this site's themes, plugins, uploads, database and/or other content directories (according to what is contained in the backup set, and your selection). Choose the components to restore:

[Do read this helpful article of useful things to know before restoring.](#)

Choose the components to restore:

- ☐ Plugins
- ☒ **Themes**
- ☒ **Uploads**
- ☐ Others
- ☐ Database

Cancel

Next

Рис. 4: Восстановление из резервной копии

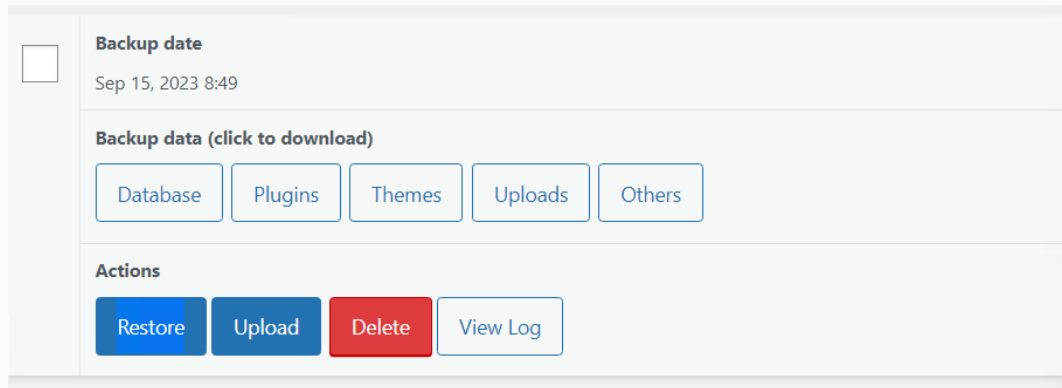


Рис. 5: Восстановление из резервной копии

Уязвимый узел: WpDiscuz

```
user@web-portal:3 ~  
ESTAB 0 0 10.10.1.22:59618 195.239.174.11:5556  
Users: (("chisel.sh",pid=1874,fd=3), ("sh",pid=1873,fd=3), ("v0k0d",pid=1840,fd=3))  
ESTAB 0 0 10.10.1.22:57628 195.239.174.11:1085  
Users: (("chisel.sh",pid=1874,fd=11))  
CLOSE-WAIT 0 10.10.1.22:39898 195.239.174.11:5557  
Users: (("chisel.sh",pid=1874,fd=12), ("sh",pid=1873,fd=12), ("v0k0d",pid=1840,fd=12))  
ESTAB 0 0 [::ffff:10.10.1.22]:80 [::ffff:10.10.1.253]:51029  
Users: (("apache2",pid=6967,fd=11))  
user@web-portal:3:~$ sudo kill 1840  
user@web-portal:3:~$ sudo ss -tnp  
State Recv-Q Send-Q Local Address:Port Peer Address  
ESTAB 0 64 10.10.1.22:22 10.10.1.253  
Users: (("sshd",pid=8093,fd=3), ("sshd",pid=7927,fd=3))  
FIN-WAIT-2 0 0 10.10.1.22:49492 10.10.2.11  
Users: (("chisel.sh",pid=1874,fd=16))  
ESTAB 0 0 10.10.1.22:59618 195.239.174.11  
Users: (("chisel.sh",pid=1874,fd=3), ("sh",pid=1873,fd=3))  
ESTAB 0 0 10.10.1.22:57628 195.239.174.11  
Users: (("chisel.sh",pid=1874,fd=11))  
CLOSE-WAIT 1 0 10.10.1.22:39898 195.239.174.11  
Users: (("chisel.sh",pid=1874,fd=12), ("sh",pid=1873,fd=12))  
ESTAB 0 0 [::ffff:10.10.1.22]:80 [::ffff:10.10.1.253]  
Users: (("apache2",pid=6965,fd=11))  
user@web-portal:3:~$ sudo kill 1873  
user@web-portal:3:~$ sudo kill 1874  
user@web-portal:3:~$ sudo ss -tnp  
State Recv-Q Send-Q Local Address:Port Peer Address  
ESTAB 0 64 10.10.1.22:22 10.10.1.253  
Users: (("sshd",pid=8093,fd=3), ("sshd",pid=7927,fd=3))  
FIN-WAIT-2 0 0 10.10.1.22:49492 10.10.2.11  
LAST-ACK 1 1 10.10.1.22:39898 195.239.174.11  
ESTAB 0 0 [::ffff:10.10.1.22]:80 [::ffff:10.10.1.253]  
Users: (("apache2",pid=1098,fd=11))  
user@web-portal:3:~$ sudo ss -tnp  
State Recv-Q Send-Q Local Address:Port Peer Address  
ESTAB 0 64 10.10.1.22:22 10.10.1.253  
Users: (("sshd",pid=8093,fd=3), ("sshd",pid=7927,fd=3))  
LAST-ACK 1 1 10.10.1.22:39898 195.239.174.11
```

Рис. 6: Завершение вредоносных соединений

- Отсутствие активных соединений с хостом нарушителя
- Восстановлена оригинальная версия сайта
- Плагин деактивирован или обновлен

Уязвимый узел: RocketChat

Уязвимый узел: RocketChat



Рис. 7: Несанкционированные подключения

```
root@rocket-chat-server:/home/admin# ss -tp | grep "195."
ESTAB      0          0          10.10.2.22:45662          195.239.174.11:5559
  users: ( ("testsystem",pid=1941,fd=3) )
root@rocket-chat-server:/home/admin# dd -K dst 195.239.174.11 fport = 5559
dd: invalid option -- 'K'
Try 'dd --help' for more information.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 fport = 5559
Error: an inet prefix is expected rather than "fport".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 port = 5559
Error: an inet prefix is expected rather than "port".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 dport = 5559
Netid State  Recv-Q  Send-Q   Local Address:Port      Peer Address:Port Process
tcp    ESTAB   0        0      10.10.2.22:45662      195.239.174.11:5559
root@rocket-chat-server:/home/admin#
```

Рис. 8: Создание backdoor-соединений 2

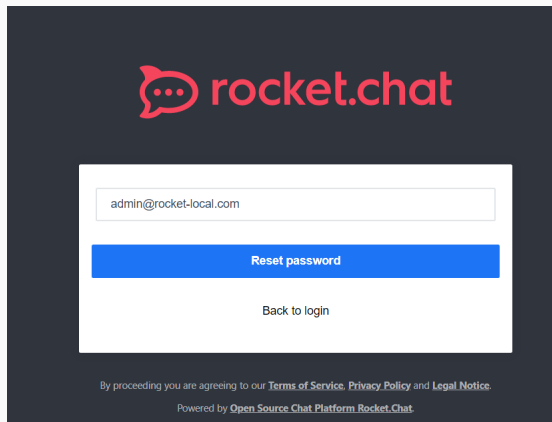
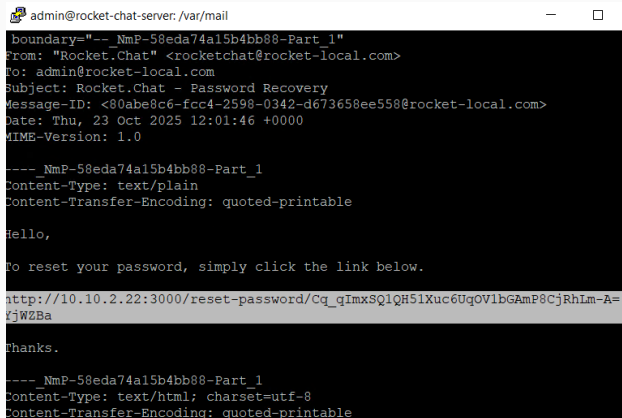


Рис. 9: Сброс пароля администратора

Уязвимый узел: RocketChat



```
admin@rocket-chat-server: /var/mail
boundary="--_NmP-58eda74a15b4bb88-Part_1"
From: "Rocket.Chat" <rocketchat@rocket-local.com>
To: admin@rocket-local.com
Subject: Rocket.Chat - Password Recovery
Message-ID: <80abe8c6-fcc4-2598-0342-d673658ee558@rocket-local.com>
Date: Thu, 23 Oct 2025 12:01:46 +0000
MIME-Version: 1.0

----_NmP-58eda74a15b4bb88-Part_1
Content-Type: text/plain
Content-Transfer-Encoding: quoted-printable

Hello,

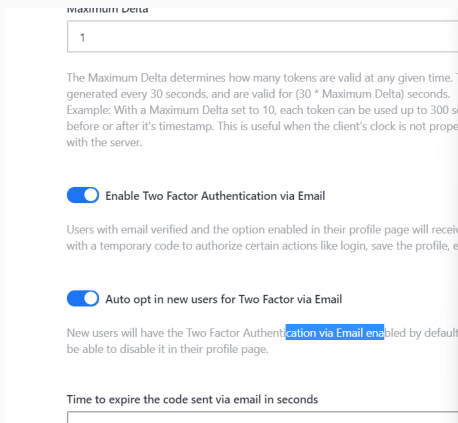
To reset your password, simply click the link below.

http://10.10.2.22:3000/reset-password/Cq\_qImxSQ1QH51Xuc6UqOV1bGAmP8CjRhLm-A=fjWZBa

Thanks.

----_NmP-58eda74a15b4bb88-Part_1
Content-Type: text/html; charset=utf-8
Content-Transfer-Encoding: quoted-printable
```

Рис. 10: Сброс пароля администратора 2



The screenshot shows the 'Two Factor Authentication via Email' settings in RocketChat. At the top, there is a 'Maximum Delta' input field containing the value '1'. Below this is a text block explaining that the Maximum Delta determines how many tokens are valid at any given time, generated every 30 seconds, and are valid for (30 * Maximum Delta) seconds. An example is provided: 'With a Maximum Delta set to 10, each token can be used up to 300 seconds before or after its timestamp. This is useful when the client's clock is not properly synchronized with the server.' Below the text block are two toggle switches, both of which are turned on. The first toggle is labeled 'Enable Two Factor Authentication via Email'. The second toggle is labeled 'Auto opt in new users for Two Factor via Email'. Below the second toggle is a text block stating: 'New users will have the Two Factor Authentication via Email enabled by default and be able to disable it in their profile page.' At the bottom of the settings section is a label 'Time to expire the code sent via email in seconds' followed by an input field containing the value '300'.

Maximum Delta

1

The Maximum Delta determines how many tokens are valid at any given time. Tokens are generated every 30 seconds, and are valid for (30 * Maximum Delta) seconds. Example: With a Maximum Delta set to 10, each token can be used up to 300 seconds before or after its timestamp. This is useful when the client's clock is not properly synchronized with the server.

☒ Enable Two Factor Authentication via Email

Users with email verified and the option enabled in their profile page will receive a temporary code to authorize certain actions like login, save the profile, etc.

☒ Auto opt in new users for Two Factor via Email

New users will have the Two Factor Authentication via Email enabled by default and be able to disable it in their profile page.

Time to expire the code sent via email in seconds

300

Рис. 11: Настройка

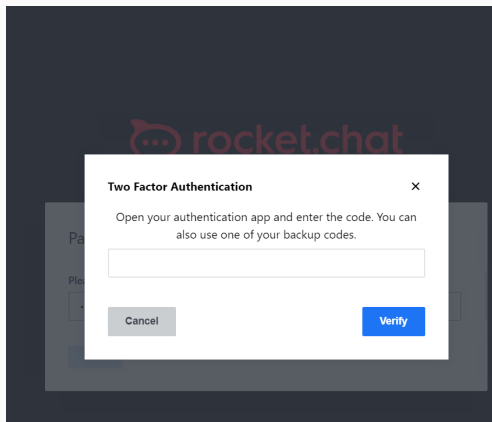


Рис. 12: Настройка

Role Editing

✕

Role

user

Description

Description

Leave the description field blank if you dont want to show the role

Scope

Global

▼

Users must use Two Factor Authentication

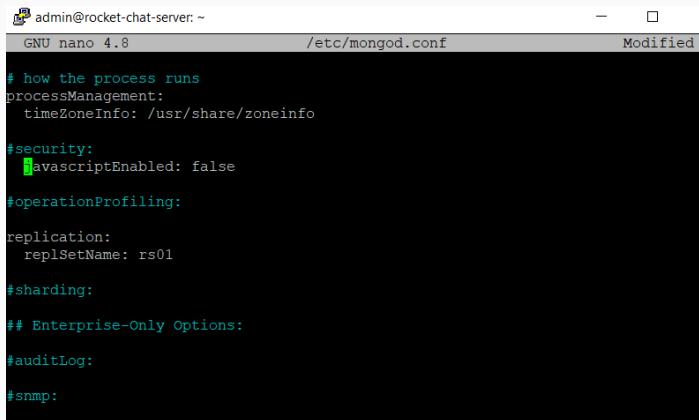
☒

Save

Users in role

Рис. 13: Настройка

Уязвимый узел: RocketChat



```
admin@rocket-chat-server: ~  
GNU nano 4.8 /etc/mongod.conf Modified  
  
# how the process runs  
processManagement:  
  timeZoneInfo: /usr/share/zoneinfo  
  
#security:  
  javascriptEnabled: false  
  
#operationProfiling:  
  
replication:  
  replSetName: rs01  
  
#sharding:  
  
## Enterprise-Only Options:  
  
#auditLog:  
  
#snmp:
```

Рис. 14: Отключение выполнения JavaScript в MongoDB

Уязвимый узел: RocketChat

```
root@rocket-chat-server: /home/admin
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 fport = 5559
Error: an inet prefix is expected rather than "fport".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 port = 5559
Error: an inet prefix is expected rather than "port".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 dport = 5559
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
tcp ESTAB 0 0 10.10.2.22:45662 195.239.174.11:5559
root@rocket-chat-server:/home/admin# sudo nano /etc/mongod.conf
root@rocket-chat-server:/home/admin# sudo systemctl stop rocketchat.service
root@rocket-chat-server:/home/admin# mongo rocketchat --eval "db.dropDatabase()"
MongoDB shell version v4.2.19
connecting to: mongod://127.0.0.1:27017/rocketchat?compressors=disabled&gssapiServiceName=mongod
Implicit session: session { "id" : UUID("250a58d8-dff9-4fe9-9d54-d5822e770a77") }
MongoDB server version: 4.2.19
{
  "dropped" : "rocketchat",
  "ok" : 1,
  "$clusterTime" : {
    "clusterTime" : Timestamp(1761222028, 73),
    "signature" : {
      "hash" : BinData(0,"AAAAAAAAAAAAAAAAAAAAAAAAAAAA="),
      "keyId" : NumberLong(0)
    }
  },
  "operationTime" : Timestamp(1761222028, 73)
}
root@rocket-chat-server:/home/admin# sudo mongorestore --db rocketchat --drop /var/backups/mongobackups/rocketchat
2025-10-23T12:21:07.259+0000 the --db and --collection args should only be used when restoring from a BSON file. Other uses are deprecated and will not exist in the future; use --nsinclude instead
2025-10-23T12:21:07.260+0000 building a list of collections to restore from /var/backups/mongobackups/rocketchat dir
2025-10-23T12:21:07.266+0000 reading metadata for rocketchat.rocketchat_settings from /var/backups/mongobackups/rocketchat/rocketchat_settings.metadata.json
2025-10-23T12:21:07.267+0000 reading metadata for rocketchat.rocketchat_permissions from /var/backups/mongobackups/rocketchat/rocketchat_permissions.metadata
```

Рис. 15: Восстановление базы данных

- Успешная аутентификация с двухфакторной проверкой
- Отсутствие вредоносных соединений
- Корректная работа всех функций RocketChat

Уязвимый узел: Proxylogon

```
[w3wp.exe]  
TCP    10.10.2.11:7796      195.239.174.11:5558  ESTABLISHED  7308  
[powershell.exe]  
TCP    10.10.2.11:7797      195.239.174.11:5558  ESTABLISHED  14228  
[powershell.exe]  
TCP    10.10.2.11:7889      ad:msft-gc           ESTABLISHED  10200
```

Рис. 16: Установление meterpreter-сессий

Уязвимый узел: Proxylogon

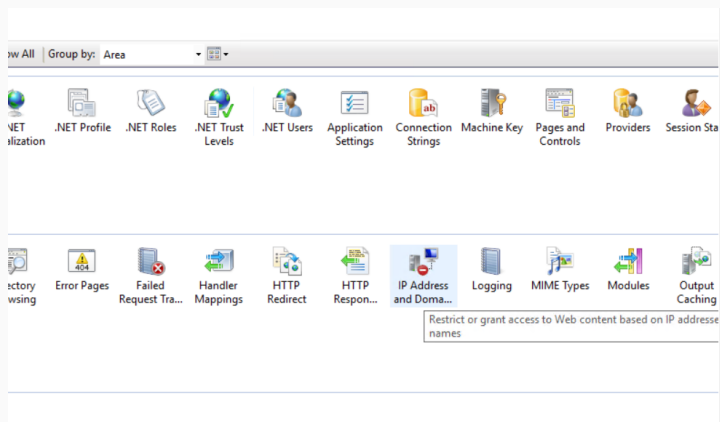


Рис. 17: Блокировка доступа

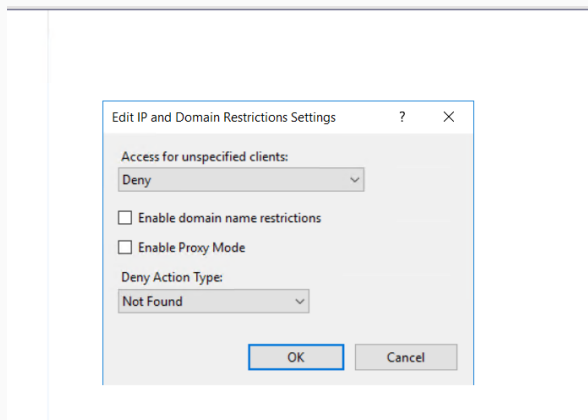


Рис. 18: Блокировка доступа

```
C:\Users\administrator.AMPIRE>cc  
  
C:\Users\administrator.AMPIRE>taskkill /PID 7308 /F  
SUCCESS: The process with PID 7308 has been terminated.  
  
C:\Users\administrator.AMPIRE>taskkill /PID 14228 /F  
SUCCESS: The process with PID 14228 has been terminated.  
  
C:\Users\administrator.AMPIRE>_
```

Рис. 19: Завершение вредоносных процессов

- Отсутствие несанкционированных подключений
- Невозможность доступа к /еср извне
- Отсутствие вредоносных файлов и процессов

В ходе лабораторной работы успешно проанализированы и нейтрализованы уязвимости трех различных веб-приложений:

1. **WpDiscuz** - уязвимость типа RCE через загрузку файлов
2. **RocketChat** - комбинация NoSQL-инъекции и уязвимости ядра ОС
3. **Proxylogon** - комплексная атака на Exchange Server

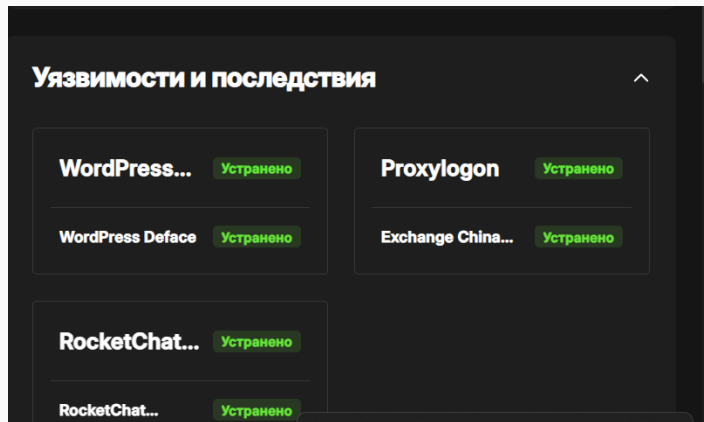


Рис. 20: Выполнение работы

Завершение работы

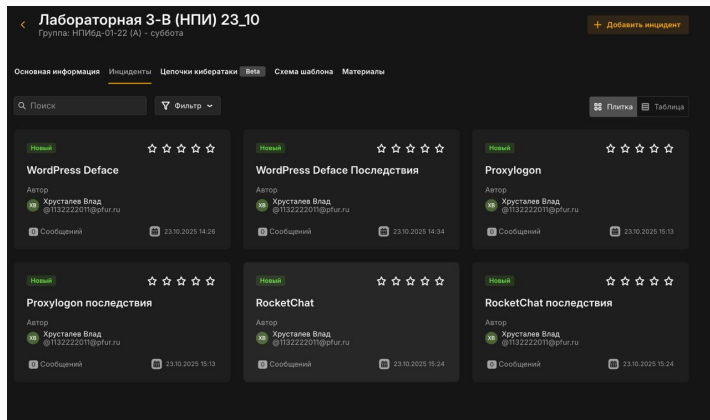


Рис. 21: Заполнение инцидентов